EXE-SOC Usage Playbook

How to run this tool well, from first install to daily work. Follow the phases in order; each one builds on the last.

Phase 1: Set up safely (first hour)

1. **Start clean.** `./run.sh` (Linux) or `run.bat` as Administrator (Windows). Use `--demo` only to practise; never for real monitoring. Stop and run `python app.py --reset` before going live if you ever used demo data.
2. **Change the default passwords at once.** Settings > Change my password, or `python app.py --set-login`. Set `SOC_ADMIN_PASSWORD`, `SOC_ANALYST_PASSWORD`, `SOC_VIEWER_PASSWORD` before the first run if you can.
3. **Give people the right role.** viewer = read only, analyst = triage and respond, admin = rules, playbooks, settings, users. Most people should be analyst or viewer.
4. **Add every computer you care about.** Endpoints > Add computer (agent) generates the exact command. Add servers first, then admin PCs, then the rest.
5. **Turn on the logs that matter.**
   - Windows: run `tools/enable_windows_auditing.bat` once as Administrator on each PC (process command lines, logons, PowerShell logging). Install Sysmon if you can.
   - Linux: run with `sudo` so the journal and `auth.log` can be read.
   - Routers, firewalls: send syslog (`SOC_SYSLOG_PORT=5514`).
6. **Confirm data is flowing.** Open Logs, pick a device, and check events arrive within seconds. No logs means no detections, so fix this before anything else.

Phase 2: Tune before you trust it (first week)

Goal: alerts you can believe. An alert nobody trusts is worse than none.

1. **Set the thresholds** in Settings: brute-force count and window, de-duplication seconds, offline minutes, retention days, and business hours (e.g. `08:00-18:00`) for the after-hours login alert.
2. **Add detection rules for the attacks you actually face.** Detection rules > Rule library. Add by attack, not all at once. Good starting set:
   - Public web server: Web Attacks, Web Shell, Recon.
   - Windows estate: Credential Dumping, Ransomware, Defense Evasion, Lateral Movement.
   - Linux servers: Brute Force, Persistence, Privilege Escalation.
3. **Test each rule first.** For custom rules use *Test on recent logs*; it counts matches in the last 2,000 logs without creating alerts. A rule that matches hundreds of normal lines needs a tighter pattern or a higher threshold.
4. **Add playbooks one at a time** (Playbooks > Playbook library). Start with `notify` and `create_case`. Add `block_ip` and `isolate_endpoint` only after a week of watching what fires.
5. **Load your own knowledge.** Add known-bad IPs to Threat Intelligence. Any alert from a listed IP is raised to Critical automatically.
6. **Disable, do not delete,** a rule that is too noisy. You can switch it back on after tuning.

Phase 3: The daily routine (15 minutes)

Step	Where	What to look for
1	**Dashboard**	Critical and High counts, anything new since yesterday, offline endpoints
2	**Alerts**	Work Critical, then High. Ignore Low until the week-end review
3	**Endpoints**	At Risk or Offline devices. Offline can mean an agent stopped, or an attacker did it
4	**Cases**	Open cases with no owner. Assign and update every one
5	**Playbooks**	Run counts. A playbook that ran many times may be reacting to noise

Phase 4: Triage one alert (the core skill)

For every alert, answer five questions in this order:

1. **What fired?** Read the title, severity, MITRE technique and the recommended steps in the alert detail.
2. **Is it real?** Open the raw log. Does the text really show the attack, or only look like it?
3. **Who and where?** Which user, device and source IP. Is the IP on the threat list? Is it inside your network?
4. **What else did they do?** Use Activity (related activity of the same user within 15 minutes) and Search, for example `index=events host=PC1 | stats count by activity`.
5. **Decide:** one of the four outcomes below.

Outcome	Action
False positive	Resolve with a note. If it repeats, tune or disable the rule
Real, contained, low impact	Block the IP if external, resolve with a note
Real, needs investigation	Create or add to a **Case**, assign an owner, add the alert
Real and spreading or critical	Isolate the endpoint, block the IP, escalate, then investigate

Always write a short note. It is your audit trail and your future self's memory.

Phase 5: Response guide by attack

Library IDs are the rule (R) and playbook (P) numbers in `rules_library.py`.

Attack	Typical alert	First response	Playbook
Brute force	Brute Force Login Attempt, Password Spraying	Block IP. Check for a **success after failures**; if yes, reset that password and open a case	P003, P004
Web exploitation (SQLi, Log4Shell, file inclusion)	Possible SQL Injection, Log4Shell JNDI Lookup	Block IP. Check web logs for HTTP 200 and large responses (did it work?)	P001, P002
Web shell	Web Server Spawned a Shell	Isolate the server, preserve the file, find how it was uploaded	P007, P008
Ransomware	Backup / Recovery Destruction, Shadow Copy Deleted	**Isolate immediately.** Do not reboot. Check other hosts for the same activity	P009, P010
Credential theft	Credential Dumping Attempt, LSASS dump	Isolate, reset every password used on that host, open a case	P011, P012
Defense evasion	Audit Log Cleared, Security Tool Disabled	Treat as hostile until proven otherwise. Find who and why	P013, P014
Persistence / privilege escalation	New user, SSH key added, new service	Verify it was approved change. If not, remove it and open a case	P015
Command and control / exfiltration	Reverse Shell, Connection To Suspicious Port, cloud upload tools	Isolate, identify the destination, estimate what data left	P016, P017
Scan or recon	Port Scan, Vulnerability Scanner	Block IP. Low risk alone, but note the target and watch for follow-up	P005
Cryptomining	Miner Process / Pool Connection	Isolate, kill the process, find the entry point	P020

Phase 6: Cases and reporting

- **One case per incident,** not per alert. Add all related alerts to it.
- Record in the case: what happened, when, what was affected, what you did, what is still open.
- Close a case only after the root cause is known and the fix is verified.
- Use **Reports** weekly: alert counts by severity, top sources, MITRE spread. Share it with whoever owns the risk.

Weekly and monthly upkeep

Weekly (30 minutes)

- Review Low and Medium alerts for patterns.
- Review rule hit counts: rules with zero hits may be broken, rules with huge counts are noisy.
- Check the Vulnerabilities page and patch the Critical ones.
- Confirm every agent still reports in (Endpoints).

Monthly

- Review users: remove people who left, check roles.
- Review the blocklist and remove stale entries.
- Check disk space and retention (default 90 days).
- Back up `soc.db` and `.secret`. Never copy them to another machine as a way to move the tool.
- Test one rule end to end, for example the EICAR file for malware scanning.

Safety rules (read these twice)

- **Isolation cuts your remote access too.** On the agent set `SOC_ISOLATE_ALLOW="your.admin.ip"` first, or you cannot reach the machine while it is isolated.
- **Blocks are real only with** `--enforce` (agents) or `SOC_ENFORCE=1` (the SOC computer). Without it, blocks are only recorded.
- **Spoofed sources.** A flood alert can carry a fake IP. Review the blocklist after automatic blocks.
- **Never auto-block** shared addresses such as your office NAT or a VPN. The tool will not block loopback or its own addresses, but it cannot know your office address.
- **Custom rules run only if no built-in rule fired** for the same log line.
- **Counters for threshold rules reset** when the server restarts.
- **Detection is pattern-based.** It finds known attack text, not unknown behaviour. Treat it as a monitoring aid and keep patching, MFA and backups.

Quick troubleshooting

Problem	Check
No alerts at all	Are logs arriving (Logs page)? Is a matching rule added and enabled?
Too many alerts	Raise the threshold, tighten the pattern, disable the rule, or raise the minimum severity of the playbook
Agent not showing	Wrong server URL or API key, firewall on port 5000, agent not run as admin/root
Locked out of login	Restart the server, or run `python app.py --set-login --password NewPass1`
Block did nothing	Agent started without `--enforce`, or not root/Administrator
Old data on a new PC	`soc.db` is moved aside automatically; run `python app.py --reset` for a fresh start

Your first-week checklist

[ ] Passwords changed, roles assigned
[ ] All key computers added and sending logs
[ ] Windows auditing script run on every Windows PC
[ ] Business hours and thresholds set
[ ] Rules added for your top three attack types, each tested
[ ] Notify and case playbooks on; block and isolate playbooks reviewed
[ ] Threat list loaded with known-bad IPs
[ ] `SOC_ISOLATE_ALLOW` set on agents
[ ] Backup of `soc.db` and `.secret` taken
[ ] One practice alert triaged end to end and a case closed